

AURORA

BANCO DIGITAL E SERVIÇOS FINANCEIROS

POLÍTICA DE SEGURANÇA DA INFORMAÇÃO E PREVENÇÃO DE FRAUDES

PROPÓSITO

Estabelecer princípios, responsabilidades, controles e procedimentos para proteger clientes, colaboradores, parceiros, dados e recursos do Banco Aurora contra incidentes de segurança, fraudes, uso indevido e interrupções operacionais.

Item	Definição
Empresa	Banco Aurora S.A. — instituição financeira/fintech fictícia
Documento	Política de Segurança da Informação e Prevenção de Fraudes
Versão	1.0
Data de emissão	19 de agosto de 2026
Classificação	Uso corporativo — documento de referência
Aprovação simulada	Conselho de Administração / Diretoria Executiva
Periodicidade de revisão	No mínimo anual e sempre que houver mudança relevante de risco ou regulamentação

Observação: esta é uma política fictícia. Ela não representa uma autorização, licença, enquadramento prudencial ou posição oficial do Banco Central, da ANPD ou de qualquer órgão público.

Controle do documento

Versão	Data	Responsável	Descrição
1.0	19/08/2026	Diretoria de Riscos e Segurança	Emissão inicial da política consolidada.
1.1	A definir	Comitê de Segurança	Revisões decorrentes de testes, auditorias ou alterações regulatórias.
2.0	A definir	Conselho de Administração	Revisão estrutural ou mudança relevante do modelo de negócio.

NOTA DE GOVERNANÇA

A política deve ser aprovada pela instância competente, comunicada aos colaboradores e terceiros relevantes e mantida disponível em versão controlada. Nenhuma área pode criar procedimento local que contradiga esta política sem aprovação formal da Segurança, Riscos, Privacidade e/ou Compliance, conforme o tema.

Sumário executivo

O Banco Aurora adota uma abordagem de segurança baseada em risco, prevenção em camadas e resposta coordenada. O objetivo é reduzir a probabilidade e o impacto de incidentes que possam comprometer a confidencialidade, integridade ou disponibilidade de informações e serviços financeiros, além de proteger os clientes contra golpes e fraudes.

A política integra segurança da informação, cibersegurança, prevenção a fraudes, proteção de dados pessoais, continuidade de negócios e gestão de terceiros. Em um ambiente digital, controles técnicos não são suficientes: a Aurora deve combinar autenticação forte, monitoramento transacional, análise comportamental, gestão de vulnerabilidades, treinamento, segregação de funções, rastreabilidade e uma cultura organizacional orientada à prevenção.

No contexto brasileiro, a proteção de dados pessoais deve observar a Lei Geral de Proteção de Dados Pessoais — LGPD (Lei nº 13.709/2018), que estabelece princípios, direitos e obrigações relacionados ao tratamento de dados pessoais. A própria ANPD orienta que medidas técnicas e administrativas de segurança sejam adotadas para prevenir acessos não autorizados e situações acidentais ou ilícitas envolvendo dados pessoais. [1][2]

O desenho final dos controles deve ser compatível com o enquadramento regulatório da instituição. A Resolução CMN nº 4.893/2021 trata de segurança cibernética para instituições em seu âmbito; a Resolução BCB nº 85/2021 trata de instituições de pagamento e outros participantes definidos no seu escopo. Já a Resolução BCB nº 142/2021 disciplina prevenção de fraudes em serviços de pagamento, com alterações recentes; a Resolução BCB nº 584/2026 prevê novas alterações com vigência em 1º de janeiro de 2027. [3][4][5]

Sumário

1. Objetivo, escopo e princípios
 2. Contexto de risco do Banco Aurora
 3. Governança e responsabilidades
 4. Classificação e proteção das informações
 5. Gestão de acessos, identidades e autenticação
 6. Segurança de aplicações, infraestrutura e nuvem
 7. Prevenção, detecção e resposta a fraudes
 8. Prevenção contra golpes e engenharia social
 9. Proteção de dados pessoais e LGPD
 10. Gestão de incidentes de segurança e privacidade
 11. Continuidade de negócios e resiliência operacional
 12. Segurança de terceiros e cadeia de suprimentos
 13. Monitoramento, auditoria e métricas
 14. Conformidade, sanções e exceções
 15. Plano de implementação e melhoria contínua
 16. Anexos e modelos operacionais
- Referências normativas e fontes públicas

1. Objetivo, escopo e princípios

1.1 Objetivo

Esta política estabelece os requisitos mínimos para preservar os ativos de informação do Banco Aurora e prevenir, detectar, investigar e responder a fraudes e incidentes. Ela também define diretrizes para proteção de dados pessoais, segurança de canais digitais, serviços financeiros, infraestrutura tecnológica, ambientes de nuvem, dispositivos, integrações e relações com terceiros.

1.2 Escopo

Aplica-se a todos os colaboradores, administradores, estagiários, prestadores de serviços, parceiros, fornecedores e terceiros que acessem sistemas ou tratem informações em nome da Aurora. Abrange escritórios, ambientes de desenvolvimento e produção, aplicativos móveis, internet banking, APIs, sistemas internos, ferramentas de atendimento, bancos de dados, serviços em nuvem, canais de pagamento e processos manuais relacionados à operação.

1.3 Princípios

- Segurança por desenho: controles devem ser incorporados desde a concepção de produtos e processos, e não somente após sua implantação.
- Mínimo privilégio: cada identidade recebe apenas os acessos necessários para cumprir sua função.
- Defesa em profundidade: nenhum controle isolado deve ser considerado suficiente para proteger uma operação crítica.
- Rastreabilidade: ações relevantes devem gerar registros adequados para auditoria e investigação.
- Privacidade por padrão: dados pessoais devem ser tratados de modo compatível com finalidade, necessidade e segurança.
- Responsabilidade compartilhada: segurança envolve pessoas, processos e tecnologia e requer participação de todas as áreas.
- Proporcionalidade e risco: medidas devem considerar impacto, probabilidade, criticidade e custo de controles.
- Melhoria contínua: incidentes, testes, auditorias e mudanças regulatórias devem alimentar planos de melhoria.

Princípio central

A Aurora não deve depender exclusivamente da identificação posterior da fraude. Sempre que possível, o controle deve impedir ou dificultar a fraude antes da autorização da operação, sem criar barreiras desnecessárias para clientes legítimos.

2. Contexto de risco do Banco Aurora

Como banco/fintech fictício com forte presença digital, a Aurora assume riscos associados à velocidade de transações, disponibilidade permanente de canais, exposição a APIs e integrações, dependência de provedores de tecnologia e volume de dados pessoais e financeiros. O risco é ampliado quando fraudadores combinam credenciais comprometidas, engenharia social, malware, manipulação de dispositivos e contas de passagem.

2.1 Principais ameaças

Ameaça	Exemplo	Impacto potencial	Controles prioritários
Phishing / engenharia social	Cliente induzido a revelar credencial ou autorizar operação	Perda financeira e exposição de dados	MFA, alertas, educação, análise comportamental
Acesso indevido	Uso de credencial comprometida ou privilégio excessivo	Fraude, vazamento, sabotagem	IAM, menor privilégio, logs e revisão periódica
Fraude transacional	Pix, transferência ou pagamento fora do padrão	Perda financeira e dano reputacional	Motor antifraude, limites, bloqueio e revisão
Conta sintética / identidade falsa	Cadastro com dados adulterados ou inconsistentes	Lavagem, fraude e perdas	KYC, validação de identidade e análise de risco
Malware / ransomware	Comprometimento de endpoint ou servidor	Indisponibilidade e extorsão	EDR, backup, segmentação, resposta a incidentes
Terceiro comprometido	Fornecedor ou API sofre ataque	Acesso indireto aos ativos	Due diligence, contratos, monitoramento
Insider threat	Uso malicioso ou indevido de acesso legítimo	Fraude, vazamento ou sabotagem	Segregação de funções, DLP e monitoramento

2.2 Avaliação de risco

A Aurora mantém uma matriz de riscos que considera probabilidade e impacto. Riscos críticos devem possuir responsável nomeado, plano de tratamento e prazo definido. O apetite a risco deve ser aprovado pela governança e revisado periodicamente.

Impacto / Probabilidade	Baixa	Média	Alta	Muito alta
Baixo	Baixo	Baixo	Moderado	Moderado
Médio	Baixo	Moderado	Alto	Alto
Alto	Moderado	Alto	Alto	Crítico
Muito alto	Moderado	Alto	Crítico	Crítico

Criticidade

Fraudes que possam afetar grande número de clientes, contas privilegiadas, sistemas críticos, credenciais de alto impacto ou dados pessoais em escala devem ser tratadas como eventos prioritários.

3. Governança e responsabilidades

A governança de segurança deve separar responsabilidades estratégicas, táticas e operacionais. A estrutura abaixo é fictícia e deve ser ajustada à estrutura societária e regulatória real da instituição.

Função	Responsabilidades essenciais
--------	------------------------------

Função	Responsabilidades essenciais
Conselho de Administração	Aprovar a política e o apetite de risco; supervisionar riscos relevantes; acompanhar indicadores e planos de tratamento.
Diretoria Executiva	Garantir recursos e patrocínio; integrar segurança à estratégia; decidir sobre riscos residuais elevados.
CISO / Segurança	Definir padrões técnicos; coordenar SOC, vulnerabilidades, incidentes e arquitetura de segurança.
Diretoria de Riscos	Manter metodologia de risco; consolidar riscos; testar controles; acompanhar perdas e KRIs.
Compliance / PLD, conforme aplicável	Avaliar aderência normativa e conflitos de interesses; apoiar investigação e comunicação regulatória.
Encarregado de Dados / Privacidade	Orientar tratamento de dados pessoais; apoiar atendimento a titulares e incidentes de privacidade; interface com ANPD.
Fraud Prevention	Operar modelos antifraude, regras, filas de análise e investigação; monitorar indicadores e perdas evitadas.
Tecnologia / DevSecOps	Implementar controles de acesso, segurança de código, infraestrutura, logs, patching e resiliência.
Jurídico	Orientar interpretação legal, contratos, preservação de evidências e comunicações formais.
Colaboradores e terceiros	Cumprir políticas, proteger credenciais, reportar eventos e participar de treinamentos.

3.1 Comitês e fóruns

- Comitê de Segurança e Ciber-risco: fórum mensal para incidentes, vulnerabilidades críticas, ameaças e decisões técnicas relevantes.
- Comitê de Fraudes e Risco Operacional: fórum semanal ou quinzenal para perdas, tentativas, tendências, regras e casos relevantes.
- Comitê de Privacidade: fórum periódico para registros de tratamento, avaliações de impacto, incidentes e direitos dos titulares.
- Sala de crise: acionada para eventos graves, com participação de Segurança, Tecnologia, Operações, Jurídico, Comunicação e áreas de negócio.

4. Classificação e proteção das informações

Toda informação deve possuir tratamento compatível com seu valor, sensibilidade e impacto de divulgação, alteração ou indisponibilidade. A classificação deve acompanhar o ciclo de vida da informação, desde a criação até o descarte.

Classificação	Exemplos	Requisitos mínimos
Pública	Informações institucionais aprovadas para divulgação	Integridade, revisão e aprovação para publicação.
Interna	Procedimentos internos, indicadores não públicos	Acesso restrito a colaboradores e terceiros autorizados.
Confidencial	Contratos, estratégias, relatórios internos, dados financeiros operacionais	Controle de acesso, criptografia em trânsito, logs e compartilhamento controlado.

Classificação	Exemplos	Requisitos mínimos
Restrita / Sensível	Dados pessoais, credenciais, chaves, informações de segurança, evidências de fraude	Mínimo privilégio, criptografia adequada, monitoramento reforçado e retenção controlada.

4.1 Ciclo de vida

1. Criar e registrar a informação com classificação e proprietário definido.
2. Armazenar em ambiente aprovado, com controle de acesso e proteção técnica adequada.
3. Compartilhar somente com destinatários legitimados e conforme finalidade.
4. Conservar pelo período necessário e segundo requisitos legais, regulatórios e operacionais.
5. Eliminar ou anonimizar de forma segura, quando aplicável, com evidência do descarte.

Regra para dados pessoais

A classificação da informação deve ser compatível com o contexto de proteção de dados. A Aurora deve evitar acesso, cópia, exportação ou compartilhamento desnecessário de dados pessoais, especialmente quando um resultado operacional puder ser alcançado com dados minimizados ou pseudonimizados.

5. Gestão de acessos, identidades e autenticação

A identidade digital é um ativo de segurança crítico. Todo acesso deve estar associado a uma identidade única, ser justificável pelo negócio e ser revogado quando deixar de ser necessário.

5.1 Controles obrigatórios

- MFA para acesso administrativo, ambientes críticos e aplicações que tratem informações sensíveis, observadas as exceções formalmente aprovadas.
- Processo de admissão, mudança de função e desligamento conectado ao gerenciamento de identidades.
- Revisão periódica de acessos privilegiados e de acessos a dados restritos.
- Contas nominativas; contas genéricas somente quando tecnicamente justificadas e com rastreabilidade individual.
- Uso de cofres de credenciais e mecanismos de gestão de segredos para chaves, tokens e senhas de serviço.
- Segregação de funções para operações de alto risco, como alteração de limites, criação de beneficiários, liberação de pagamentos e administração de regras antifraude.
- Bloqueio ou elevação de autenticação diante de sinais anômalos, incluindo mudanças de dispositivo, localização ou comportamento.

5.2 Privilégios críticos

Acessos com capacidade de alterar infraestrutura, regras de autenticação, dados mestres, limites financeiros, mecanismos antifraude ou registros de auditoria devem ser considerados privilegiados. Tais acessos devem possuir aprovação, monitoração reforçada, revisão recorrente e registro de atividades.

6. Segurança de aplicações, infraestrutura e nuvem

A Aurora deve adotar práticas de desenvolvimento seguro e operação resiliente. A segurança deve estar integrada ao ciclo de desenvolvimento, incluindo requisitos, modelagem de ameaças, análise de código, testes, gestão de dependências e monitoramento em produção.

6.1 Segurança de software

- Revisão de requisitos de segurança antes da implementação de produtos e integrações críticas.
- Análise automatizada de código e dependências, com tratamento priorizado de vulnerabilidades relevantes.
- Testes de segurança e testes de intrusão proporcionais ao risco antes de liberações críticas e periodicamente.
- Proteção de segredos, certificados e chaves fora do código-fonte.
- Logs de segurança estruturados e protegidos contra alteração indevida.
- Revisão das permissões de APIs e validação de entradas e parâmetros.

6.2 Infraestrutura e nuvem

- Segmentação de redes e ambientes para reduzir movimento lateral.
- Hardening de servidores, endpoints e serviços conforme padrões internos.
- Gestão de vulnerabilidades com prioridade para ativos expostos à internet e sistemas críticos.
- Backups protegidos contra exclusão ou criptografia indevida e submetidos a testes de restauração.
- Criptografia apropriada para dados em trânsito e em repouso, com gestão segura de chaves.
- Monitoramento de configurações de nuvem e redução de exposição pública desnecessária.

Terceirização não transfere responsabilidade

Quando serviços de processamento, armazenamento ou computação em nuvem são terceirizados, a Aurora deve manter governança sobre segurança, disponibilidade, integridade, confidencialidade e continuidade. O fornecedor deve ser tratado como parte da superfície de risco, não como um “ambiente fora da empresa”.

7. Prevenção, detecção e resposta a fraudes

A prevenção de fraudes é um processo contínuo que combina autenticação, análise de risco, monitoramento transacional, listas e inteligência, regras determinísticas, modelos estatísticos, revisão humana e cooperação com áreas internas e externas, conforme permitido pela legislação.

7.1 Arquitetura em camadas

Camada	Função	Exemplos
1. Identidade	Reduzir risco na entrada	KYC, validação documental, prova de vida, consistência cadastral
2. Acesso	Evitar tomada de conta	MFA, análise de dispositivo, risco de sessão
3. Comportamento	Identificar desvios	Novo dispositivo, alteração cadastral, padrão incomum
4. Transação	Avaliar operação	Valor, frequência, favorecido, horário, contexto e histórico

Camada	Função	Exemplos
5. Rede / relacionamento	Encontrar padrões coordenados	Contas relacionadas, dispositivos, IPs, beneficiários recorrentes
6. Decisão	Aplicar tratamento de risco	Aprovar, autenticar adicionalmente, reter, encaminhar ou bloquear
7. Pós-evento	Aprender com ocorrências	Investigação, recuperação, ajuste de regras e lições aprendidas

7.2 Operações de maior risco

- Criação ou alteração de beneficiários e chaves de pagamento.
- Aumento de limite, mudança de dispositivo, alteração de senha ou recuperação de acesso.
- Transferências incompatíveis com histórico, renda, perfil ou contexto do cliente.
- Movimentação logo após alteração de cadastro ou recuperação de conta.
- Operações com indícios de automação abusiva, tomada de conta ou uso de credenciais comprometidas.
- Sequências de transações rápidas entre contas com padrões atípicos.

7.3 Regras de decisão e tratamento

Nível	Condição típica	Ação
Baixo	Operação coerente com perfil e histórico	Fluxo normal + registro
Moderado	Divergência relevante, porém sem forte evidência de fraude	Autenticação adicional / análise automática
Alto	Múltiplos indicadores de risco ou anomalia forte	Retenção temporária, revisão ou confirmação contextual
Crítico	Indícios robustos de fraude, invasão ou comprometimento	Bloqueio preventivo, investigação, preservação de evidências e comunicação conforme aplicável

A Resolução BCB nº 142 estabelece procedimentos e controles relacionados à prevenção de fraudes em serviços de pagamento e prevê, entre outros pontos, registros diários das ocorrências de fraude ou tentativa e relatório consolidado mensal com medidas adotadas. A Aurora deverá refletir essas obrigações quando estiver no escopo regulatório correspondente. [4]

8. Prevenção contra golpes e engenharia social

Fraudes nem sempre dependem de falha técnica. Em golpes de engenharia social, o fraudador explora confiança, urgência, medo ou autoridade para induzir o cliente ou colaborador a realizar uma ação. A Aurora deve desenhar experiências que reduzam a chance de uma decisão manipulada.

8.1 Controles de produto

- Mensagens claras para alertar sobre tentativas de fraude e reforçar que a instituição não solicita senhas, códigos ou acesso remoto.
- Confirmações contextuais para operações sensíveis, evitando interfaces que incentivem o clique automático.

- Alertas de mudança de dispositivo, senha, endereço e beneficiários.
- Mecanismos de fricção adicional quando o risco for elevado, sem transformar todo cliente em suspeito.
- Canais oficiais facilmente identificáveis para que o cliente possa confirmar a autenticidade de um contato.

8.2 Treinamento interno

Todos os colaboradores devem receber treinamento inicial e reciclagem periódica sobre phishing, proteção de credenciais, uso seguro de dispositivos, reporte de incidentes, privacidade e sinais de fraude. Áreas de atendimento, operações, tecnologia, fraude e pagamentos devem receber conteúdo aprofundado.

Regra de ouro

Nenhum colaborador deve contornar controles de segurança para “agilizar” uma operação. Quando houver dúvida, a pessoa deve interromper a ação e acionar o canal oficial de suporte ou segurança.

9. Proteção de dados pessoais e LGPD

A LGPD aplica-se ao tratamento de dados pessoais realizado por pessoas naturais ou jurídicas de direito público ou privado, inclusive em meios digitais, com o objetivo de proteger direitos fundamentais de liberdade e privacidade. [1] Para uma instituição financeira digital, a proteção de dados é parte central da governança de segurança, e não um projeto separado.

9.1 Diretrizes de privacidade

- Definir finalidades legítimas e compatíveis para cada atividade de tratamento.
- Coletar e utilizar somente os dados necessários para a finalidade, observadas as bases legais aplicáveis.
- Garantir transparência adequada ao titular sobre o uso de seus dados.
- Controlar acessos de acordo com função, necessidade e finalidade.
- Avaliar riscos de privacidade em novos produtos, integrações, modelos analíticos e processos relevantes.
- Estabelecer regras de retenção e descarte coerentes com obrigações legais e operacionais.
- Controlar transferências e compartilhamentos com terceiros, inclusive suboperadores.
- Documentar decisões e manter evidências de governança quando aplicável.

9.2 Segurança de dados pessoais

O art. 46 da LGPD determina a adoção de medidas de segurança técnicas e administrativas aptas a proteger dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou qualquer forma de tratamento inadequado ou ilícito. A ANPD destaca, em seus materiais orientativos, a importância dessas medidas e da sua aplicação desde a concepção do produto ou serviço. [1][2]

Controle	Aplicação na Aurora
Minimização	Reduzir a coleta e o uso de dados pessoais quando o objetivo puder ser alcançado com menos informação.
Pseudonimização	Substituir identificadores diretos em ambientes de análise, testes e desenvolvimento quando possível.

Controle	Aplicação na Aurora
Criptografia	Proteger dados e canais conforme risco e criticidade.
Controle de acesso	Restringir visualização, exportação e alteração a funções autorizadas.
Logs e auditoria	Registrar acessos e operações relevantes envolvendo dados restritos.
DLP / prevenção de exfiltração	Detectar transferências indevidas de informação em canais controlados.
Gestão de incidentes	Avaliar impacto sobre titulares e requisitos de comunicação quando aplicável.
Direitos dos titulares	Disponibilizar processos para atendimento de solicitações dentro dos requisitos legais.

9.3 Incidentes com dados pessoais

A existência de uma vulnerabilidade não significa, por si só, que exista um incidente de segurança comunicável. A ANPD orienta que o controlador deve avaliar o evento e, quando presentes os critérios aplicáveis — incluindo envolvimento confirmado de dados pessoais e possibilidade de risco ou dano relevante — realizar as comunicações exigidas. [6] A Aurora deverá manter um procedimento de triagem, avaliação jurídica e decisão documentada.

10. Gestão de incidentes de segurança e privacidade

Todo evento de segurança deve ser tratado de forma estruturada, priorizando proteção de clientes, contenção do dano, preservação de evidências e continuidade dos serviços críticos. O processo deve contemplar incidentes cibernéticos, fraudes, indisponibilidade, vazamentos, uso indevido de credenciais, comprometimento de terceiros e eventos físicos relevantes.

10.1 Ciclo de resposta

Etapa	Atividades
1. Preparação	Planos, contatos, ferramentas, papéis, playbooks e testes.
2. Detecção	Alertas, denúncias, SOC, monitoramento, sistemas antifraude e reports de terceiros.
3. Triagem	Classificação, impacto inicial, escopo provável e criticidade.
4. Contenção	Bloqueio de credenciais, isolamento de ativos, retenção de transações e proteção de clientes.
5. Erradicação	Remover causa, corrigir configuração, aplicar patches e eliminar persistência.
6. Recuperação	Restaurar serviços de forma segura e monitorar reincidência.
7. Aprendizado	Análise de causa raiz, relatório, ações corretivas e atualização de controles.

10.2 Severidade simulada

Nível	Critério orientativo	Exemplo	Prazo interno de escalonamento
-------	----------------------	---------	--------------------------------

Nível	Critério orientativo	Exemplo	Prazo interno de escalonamento
P1 — Crítico	Grande impacto financeiro, operacional ou de dados; sistema crítico comprometido	Fraude em escala, ransomware em produção, vazamento relevante	Imediato
P2 — Alto	Impacto relevante e limitado; potencial de escalada	Comprometimento de conta privilegiada	Até 30 min
P3 — Moderado	Impacto controlável e sem evidência de escala	Tentativa de fraude isolada sem perda material	Até 4 h
P4 — Baixo	Evento sem impacto relevante	Alerta falso ou tentativa bloqueada	Até 1 dia útil

Preservação de evidências

Logs, identificadores de transação, mensagens, cabeçalhos, dados de dispositivo e demais evidências relevantes devem ser preservados com controle de acesso e cadeia de custódia compatível com a finalidade investigativa. A preservação deve observar necessidade, proporcionalidade e regras de retenção.

11. Continuidade de negócios e resiliência operacional

A disponibilidade é componente essencial da confiança em serviços financeiros. A Aurora deve identificar processos críticos, definir objetivos de recuperação e manter alternativas para cenários de indisponibilidade tecnológica, falha de fornecedor, incidente cibernético e eventos físicos.

11.1 Requisitos

- Business Impact Analysis (BIA) para processos críticos.
- Definição de RTO e RPO compatíveis com a criticidade de cada serviço.
- Backups testados periodicamente e protegidos contra alteração ou exclusão indevida.
- Arquitetura com redundância para componentes críticos quando economicamente e tecnicamente justificável.
- Planos de comunicação de crise e contatos atualizados.
- Exercícios de continuidade e recuperação, incluindo cenários de fraude e ciberataque.
- Registro de lições aprendidas e atualização dos planos após testes ou incidentes reais.

Cenário	Resposta inicial	Recuperação
Indisponibilidade de canal digital	Acionar continuidade, comunicar clientes e verificar integridade dos dados	Restaurar serviço por ordem de criticidade e validar transações
Ransomware	Isolar ativos afetados, preservar evidências e interromper propagação	Recuperar ambiente confiável a partir de cópias seguras
Fraude em massa	Acionar crise antifraude e aumentar controles de transação	Bloquear vetores, investigar contas relacionadas e revisar regras
Falha de fornecedor crítico	Acionar SLA e contingência	Migrar ou restabelecer serviço dentro do plano de continuidade

12. Segurança de terceiros e cadeia de suprimentos

Fornecedores que processam dados, prestam serviços de tecnologia, hospedam sistemas, desenvolvem software ou interagem com clientes podem ampliar o risco operacional. A Aurora deve aplicar diligência proporcional ao risco, sem considerar certificações do fornecedor como substitutas do acompanhamento próprio.

Fase	Controles
Antes da contratação	Due diligence, análise de segurança, privacidade, continuidade, reputação e capacidade financeira quando aplicável.
Contrato	Requisitos de segurança, confidencialidade, proteção de dados, incidentes, auditoria, continuidade, subcontratação e término.
Operação	Monitoramento de SLAs, vulnerabilidades, incidentes, mudanças relevantes e evidências periódicas.
Mudanças	Avaliação adicional para alterações de arquitetura, processamento, localização de dados ou subcontratados críticos.
Encerramento	Revogação de acessos, devolução/eliminação de dados conforme contrato e comprovação de descarte quando aplicável.

13. Monitoramento, auditoria e métricas

A eficácia da política deve ser mensurada. A Aurora manterá indicadores de segurança, fraude, privacidade e continuidade, com metas e limites aprovados pela governança. Métricas devem servir à tomada de decisão, não somente à produção de relatórios.

13.1 Indicadores sugeridos

Indicador	Objetivo	Periodicidade
Taxa de fraude por volume transacionado	Medir perdas relativas	Mensal
Taxa de tentativas bloqueadas	Avaliar capacidade preventiva	Semanal/Mensal
Tempo médio de detecção (MTTD)	Medir velocidade de identificação	Mensal
Tempo médio de resposta (MTTR)	Medir velocidade de contenção/recuperação	Mensal
Vulnerabilidades críticas fora do SLA	Controlar exposição tecnológica	Semanal
Cobertura de MFA	Acompanhar proteção de acessos relevantes	Mensal
Acessos privilegiados revisados	Garantir governança de privilégio	Trimestral
Incidentes envolvendo dados pessoais	Medir risco de privacidade	Mensal
Treinamento concluído	Medir conscientização	Mensal/Trimestral

13.2 Auditorias e testes

- Auditoria interna periódica sobre desenho e operação dos controles.
- Testes de intrusão e avaliações técnicas baseadas em risco.
- Simulações de phishing e exercícios de resposta a incidentes.
- Testes de recuperação de backup e continuidade.
- Revisões de regras e modelos antifraude para verificar desempenho, falsos positivos e lacunas.
- Avaliações de fornecedores críticos.

14. Conformidade, sanções e exceções

O descumprimento desta política pode aumentar a exposição financeira, operacional, regulatória e reputacional da Aurora. Colaboradores e terceiros que violarem controles, ocultarem incidentes ou utilizarem recursos de forma indevida estarão sujeitos às medidas administrativas, contratuais ou disciplinares previstas nas regras internas e nos contratos, respeitados os procedimentos aplicáveis.

14.1 Exceções

Exceções devem ser temporárias, justificadas, documentadas e aprovadas pelo responsável competente. Toda exceção deve indicar motivo, risco residual, controles compensatórios, prazo de validade e responsável pelo encerramento. Não devem existir exceções “permanentes” disfarçadas de contingência.

Campo	Registro mínimo da exceção
Motivo	Por que o requisito não pode ser atendido agora?

Campo	Registro mínimo da exceção
Escopo	Qual sistema, processo, ativo ou equipe está afetado?
Risco	Qual a ameaça e o impacto potencial?
Mitigação	Quais controles compensatórios serão usados?
Prazo	Quando a exceção termina?
Aprovação	Quem aceitou formalmente o risco residual?

15. Plano de implementação e melhoria contínua

A implementação desta política deve ocorrer em ondas, priorizando os ativos e processos de maior risco. A cronologia abaixo é um modelo para a empresa fictícia e deve ser adaptada à realidade operacional.

Fase	Prioridades	Resultado esperado
0–30 dias	Governança, inventário de ativos, classificação de dados, canais de incidente, MFA para privilegiados	Visibilidade e controles básicos implementados
31–90 dias	IAM, logging, gestão de vulnerabilidades, regras antifraude prioritárias, treinamento inicial	Redução rápida de riscos críticos
91–180 dias	EDR, DLP conforme risco, testes de intrusão, continuidade, revisão de terceiros	Maturidade operacional intermediária
181–365 dias	Modelos avançados de risco, automação de resposta, exercícios integrados, auditorias	Maturidade e melhoria contínua

15.1 Ciclo anual de revisão

1. Reavaliar ameaças, incidentes, perdas e mudanças no negócio.
2. Revisar legislação, regulamentação e orientações aplicáveis.
3. Testar a eficácia dos controles críticos.
4. Atualizar a matriz de riscos e o apetite a risco.
5. Revisar esta política e submetê-la à aprovação competente.
6. Comunicar alterações e atualizar treinamentos e procedimentos.

Atualização regulatória relevante

A Resolução BCB nº 584, publicada em 7 de agosto de 2026, altera a Resolução BCB nº 142 e estabelece que suas alterações entrem em vigor em 1º de janeiro de 2027. A Aurora deve acompanhar a regulamentação aplicável ao seu efetivo enquadramento e adaptar procedimentos antes da data de entrada em vigor de obrigações relevantes. [5]

16. Anexos e modelos operacionais

Anexo A — Checklist de controles essenciais

- Política aprovada e comunicada aos colaboradores e terceiros relevantes.
- Inventário de ativos críticos atualizado.
- Classificação de informações e dados pessoais definida.
- MFA implantado para acessos críticos.
- Processo de admissão, alteração e desligamento de acessos operacional.
- Revisão de privilégios realizada periodicamente.
- Gestão de vulnerabilidades com SLAs definidos.
- Backups protegidos e testados.
- Logs relevantes centralizados e monitorados.
- Motor ou regras antifraude cobrindo transações críticas.
- Fluxo de tratamento de fraude e contestação de cliente definido.
- Treinamento de segurança e engenharia social realizado.
- Registro de operações de tratamento de dados pessoais mantido conforme necessidade.
- Processo de incidente com dados pessoais definido.
- Fornecedores críticos avaliados antes da contratação e monitorados.
- Testes de continuidade e resposta realizados.
- Indicadores de segurança e fraude apresentados à governança.

Anexo B — Modelo de registro de incidente

Campo	Preenchimento
ID do incidente	A-AAAAMMDD-XXXX
Data/hora de detecção	Data e hora local
Canal de detecção	SOC / antifraude / cliente / fornecedor / colaborador / outro
Classificação	P1 / P2 / P3 / P4
Sistemas afetados	Lista de ativos e serviços
Dados envolvidos	Descrever categorias sem expor dados além do necessário
Impacto estimado	Financeiro / operacional / privacidade / reputacional
Ações de contenção	Medidas adotadas imediatamente
Evidências preservadas	Logs, transações, dispositivos, tickets etc.
Responsável pelo incidente	Nome da função / equipe
Comunicações	Internas, clientes, autoridades ou terceiros, conforme aplicável
Causa raiz	Fator técnico, humano, processual ou de terceiro
Ações corretivas	Medidas para evitar recorrência
Data de encerramento	Data e hora

Anexo C — Playbook simplificado de tomada de conta (Account Takeover)

1. Identificar sinais: novo dispositivo, troca de senha, alteração cadastral, mudança de padrão e transação atípica.
2. Elevar o nível de autenticação e, quando necessário, restringir operações de alto risco.
3. Validar legitimidade por canal confiável, sem solicitar senha, token ou código de autenticação.
4. Revogar sessões e credenciais comprometidas e restaurar fatores de autenticação seguros.
5. Revisar operações recentes e contas/beneficiários relacionados.
6. Registrar evidências e classificar o caso como fraude confirmada, tentativa ou falso positivo.
7. Avaliar recuperação financeira, comunicação ao cliente e medidas adicionais.
8. Atualizar regras antifraude e realizar análise de causa raiz.

Anexo D — Matriz de responsabilidades (RACI simplificada)

Processo	Segurança	Fraude	Privacidade	Tecnologia	Riscos	Negócio
Incidente cibernético	R	C	C	R	A	C
Fraude transacional	C	R	C	C	A	C
Incidente com dados pessoais	C	C	R	C	A	C
Novo produto digital	C	C	C	R	A	R
Fornecedor crítico	C	C	C	R	A	R
Política de segurança	R	C	C	C	A	C

Legenda: R = responsável pela execução; A = accountable/aprovador; C = consultado.

Referências normativas e fontes públicas

Referências normativas e fontes públicas

- [1] **BRASIL.** Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais — LGPD.
- [2] **AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS — ANPD.** Guia Orientativo sobre Segurança da Informação para Agentes de Tratamento de Pequeno Porte.
- [3] **AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS — ANPD.** Resolução CD/ANPD nº 15, de 24 de abril de 2024. Regulamento de Comunicação de Incidente de Segurança.
- [4] **BANCO CENTRAL DO BRASIL.** Resolução CMN nº 4.893, de 26 de fevereiro de 2021. Política de segurança cibernética e requisitos aplicáveis à contratação de determinados serviços de processamento, armazenamento de dados e computação em nuvem.
- [5] **BANCO CENTRAL DO BRASIL.** Resolução BCB nº 85, de 8 de abril de 2021. Política de segurança cibernética e requisitos aplicáveis às instituições abrangidas pelo respectivo normativo.
- [6] **BANCO CENTRAL DO BRASIL.** Resolução BCB nº 142, de 23 de setembro de 2021. Procedimentos e controles para prevenção de fraudes na prestação de serviços de pagamento.

[7] **BANCO CENTRAL DO BRASIL.** Resolução BCB nº 584, de 7 de agosto de 2026. Altera a Resolução BCB nº 142/2021, observada sua respectiva entrada em vigor.

Aprovação e vigência

Este documento entra em vigor após aprovação formal da instância competente do Banco Aurora fictício. Recomenda-se revisão anual ou antecipada quando houver mudança relevante de produto, arquitetura, riscos, incidentes ou regulamentação.

Aprovação	Nome / função	Data	Assinatura
Conselho de Administração		__/__/__	
Diretoria Executiva		__/__/__	
CISO / Segurança		__/__/__	
Privacidade / Encarregado		__/__/__	